

# Detecting attacks against Apache HTTP Server

CVE-2021-41773 | Technical  
presentation draft

# Why this CVE matters

- Affected Apache HTTP Server 2.4.49
- Allowed unauthenticated path traversal and file disclosure in some configurations
- Could lead to remote code execution when CGI was enabled and access controls were missing
- It was exploited in the wild and appears in CISA's Known Exploited Vulnerabilities catalogue
- The first fix was incomplete, which led to

# Technical cause and preconditions

- A change in path normalisation mishandled encoded traversal characters
- A crafted URL could move outside the intended web directory
- File disclosure depended on exposed paths and weak access restrictions
- Remote code execution required extra conditions, including CGI support
- A version check shows exposure. It does not show that the server was attacked

# Attacker flow

- 1. Find an exposed Apache server running the affected version
- 2. Send a request containing encoded path traversal
- 3. Try to read a sensitive file or reach a CGI path
- 4. If the configuration allows it, run a command through Apache
- 5. Continue with reconnaissance, credential access, persistence, or lateral

# What defenders can observe

- HTTP logs: encoded traversal, unusual paths, CGI requests, source IP, and user agent
- Responses: unusual status codes, sizes, or errors followed by success
- Process telemetry: Apache starting a shell or another unexpected process
- File and network telemetry: sensitive-file access or outbound connections from Apache

# Proposed detection logic

- Alert on encoded or repeated traversal in an HTTP request
- Increase confidence if it targets CGI or a sensitive file path
- Correlate the request with the response status and size
- Raise severity if Apache starts a shell or interpreter afterwards
- Treat the request as an attempt, not proof of compromise

# Example alert

- Alert: Possible Apache path traversal attack
- Source: 203.0.113.44 | Target: web-01
- Request:  
`/cgi-bin/..%2e/..%2e/..%2e/..%2e/etc/passwd`
- HTTP result: 200 OK with an unusual response size
- Follow-up: apache2 spawned `/bin/sh`
- Assessment: Likely exploitation attempt; check file access and scope

# Limitations and response

- Scanners and authorised testing can create similar requests
- Proxies may decode, rewrite, or log paths differently
- Attackers can vary the encoding and request structure
- HTTP logs alone cannot prove command execution
- Preserve telemetry, check the scope, isolate confirmed execution, and patch

# Conclusion and references

- The strongest detection combines request indicators with process or network telemetry
- Report exposure, attempted exploitation, and confirmed compromise separately
- References: NVD, MITRE CVE, CISA KEV, Rapid7, Qualys, BleepingComputer